

axialoop

SVILUPPATORE

DOCUMENTAZIONE TECNICA DI SISTEMA

DocSense

Architettura · Sicurezza · Pipeline di Elaborazione

Questo documento descrive l'architettura tecnica, il modello di elaborazione, i meccanismi di sicurezza e la conformità GDPR del sistema DocSense così come è stato progettato e realizzato. È destinato a chi necessita di una comprensione tecnica precisa del sistema e della sua applicabilità a contesti di analisi documentale, compliance, reporting strutturato e gestione di flussi documentali professionali.

PRODOTTO	DocSense — Motore di analisi e sintesi documentale automatizzata		
VERSIONE DOCUMENTO	1.0 — Maggio 2026		
SVILUPPATORE	Axialoop di Di Lonardo Alessandro		
DOMINI APPLICATIVI	Analisi documentale · Compliance · Reporting strutturato · Due diligence		
FRAMEWORK SUPPORTATI	10 standard normativi pre-configurati (vedi § 09)		
CLASSIFICAZIONE	Riservato — Solo uso interno		Confidenziale · Non distribuire

Introduzione

DocSense è un motore di elaborazione documentale automatizzata. Riceve in input un pacchetto arbitrario di documenti — visure, contratti, procedure, manuali, dichiarazioni, certificazioni, documenti tecnici, atti societari, documentazione di sicurezza, documenti ambientali — e produce in pochi minuti una **relazione narrativa strutturata** che organizza, sintetizza ed espone le evidenze oggettive emerse dalla lettura sistematica dell'intero pacchetto.

Il sistema si rivolge a professionisti e organizzazioni che, nella propria attività quotidiana, devono esaminare grandi volumi di documenti eterogenei e produrre sintesi strutturate, tracciabili e ripetibili. Trova applicazione naturale in tutti i contesti in cui l'analisi documentale costituisce una fase critica del processo: gestione documentale aziendale, compliance normativa, reporting strutturato, due diligence, gap analysis, verifica documentale preliminare, screening di fornitori e partner.

■ Scopo di Questo Documento

Questo documento descrive l'architettura tecnica, i meccanismi di sicurezza e i flussi operativi del sistema così come è stato progettato e realizzato. È destinato a chi necessita di una comprensione tecnica precisa del sistema: come è strutturata la pipeline, come viene garantita la sicurezza e l'isolamento dei dati, come funziona la conformità GDPR, su quale infrastruttura il sistema opera, e come può essere adattato a verticali specifici.

Non è un manuale utente né una guida operativa. È una documentazione tecnica di riferimento sull'implementazione, pensata anche come base per la valutazione di compliance e privacy da parte di clienti, partner e responsabili della protezione dei dati.

■ Stato di Maturità

DocSense è un sistema in produzione, già testato operativamente in collaborazione con uno studio ingegneristico che opera nel settore dell'accompagnamento delle aziende manifatturiere e degli stabilimenti produttivi nei processi di certificazione, di adeguamento normativo e di conformità ambientale. Nel corso della fase di validazione operativa, il motore ha elaborato **oltre 15.000 documenti** appartenenti a tipologie eterogenee — visure camerali, DVR, procedure di gestione, manuali qualità, dichiarazioni di conformità, certificazioni di prodotto e di processo, contratti, verbali, evidenze fotografiche — confermando robustezza, accuratezza e velocità di elaborazione anche su volumi documentali estesi.

Indice

§	SEZIONE	PAG.
01	Introduzione	2
02	Stack Tecnologico & Architettura Logica	4
03	La Pipeline di Elaborazione	6
04	Motore OCR: Azure Document Intelligence	8
05	Motore di Sintesi: Azure OpenAI GPT-4.1-mini	9
06	Sicurezza: Architettura a Difesa Stratificata	11
07	GDPR Compliance: Mappatura Articolo per Articolo	14
08	Modello di Deploy: Tenant Dedicato	16
09	Framework Pre-Configurati & Verticali Applicativi	17
10	Continuità Operativa e Backup	19
11	Monitoraggio e Osservabilità	20
12	Roadmap di Evoluzione	21
13	Glossario Tecnico	22

§02

Il Cuore Tecnologico: Architettura del Sistema

Stack Tecnologico

DocSense è costruito su tecnologie enterprise-grade selezionate per affidabilità, scalabilità e conformità europea ai requisiti di trattamento dei dati personali:

LAYER	TECNOLOGIA	RUOLO
Frontend	React 18 + Vite	UI reattiva, single-page application
Backend API	FastAPI (Python 3.11)	REST API, autenticazione, orchestrazione pipeline
Application Server	uvicorn (worker pool)	ASGI server multi-worker per parallelismo
Reverse Proxy	nginx	TLS termination, security headers, rate limiting
Database	SQLite 3	Audit log, anagrafica utenti, metadati pratiche
OCR Engine	Azure Document Intelligence	Riconoscimento testo da PDF e immagini
LLM Engine	Azure OpenAI GPT-4.1-mini	Sintesi narrativa, classificazione, analisi semantica
Document builder	python-docx	Generazione report Word strutturato
Auth	JWT (HS256) + bcrypt	Sessioni stateless, hashing password
TLS	Let's Encrypt	Certificati X.509 con auto-renew
Hosting	Hetzner Cloud — Germania (EU)	Server fisico in territorio europeo
CI/CD	GitHub Actions	Test + deploy automatico su push

DOCUMENTI ELABORATI

15k+

Pacchetti documentali eterogenei

FRAMEWORK PRE-CONFIGURATI

10

Standard normativi e di settore

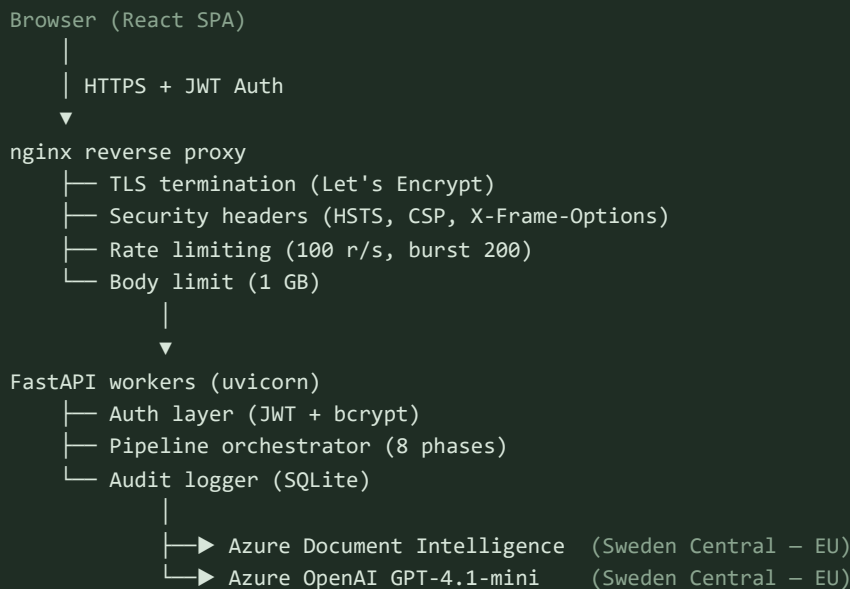
PIPELINE A FASI

8

Fasi deterministiche orchestrate

Architettura Logica

Il sistema adotta un'architettura **"Pipeline-First, Stateless-Workers"**: ogni richiesta di elaborazione attraversa una sequenza deterministica di fasi indipendenti, eseguite da worker stateless che possono essere scalati orizzontalmente. I dati documentali transitano nel sistema senza essere mai persistiti permanentemente: l'unica memoria duratura è il log di audit e i metadati di pratica.



Separazione delle Responsabilità

- **Frontend** — si occupa esclusivamente di presentazione e raccolta input. Non contiene logica di business, non gestisce segreti.
- **nginx** — è l'unico punto di contatto con la rete pubblica. Termina TLS, applica i security headers, fa enforcement del rate limiting.
- **FastAPI workers** — eseguono autenticazione, orchestrazione della pipeline di elaborazione e logging. Sono stateless: ogni richiesta è autocontenuta tramite il JWT.
- **SQLite** — contiene solo metadati operativi: utenti, pratiche elaborate, log di accesso, log di errore. **Non contiene mai il contenuto dei documenti caricati.**

PRINCIPIO CHIAVE — NO DOCUMENT PERSISTENCE

I documenti caricati non vengono mai scritti nel database. Vivono esclusivamente nella memoria del worker durante l'elaborazione e in una directory temporanea sul filesystem cifrato, per la durata strettamente necessaria al processing. Al termine dell'elaborazione vengono rimossi automaticamente.

NOTA IMPLEMENTATIVA — ZERO EGRESS NON EUROPEO

Tutti gli endpoint Azure utilizzati (Document Intelligence e OpenAI) sono configurati su region **Sweden Central**. Il sistema non comunica con servizi extra-UE in nessuna fase del processing. Non utilizza CDN americane, non chiama API di provider non europei, non esporta telemetria verso servizi terzi.

§ 03

La Pipeline di Elaborazione

■

Flusso Deterministico a 8 Fasi

Ogni richiesta di elaborazione attraversa un ciclo di vita strutturato in 8 fasi (PHASE-01 → PHASE-08), ciascuna corrispondente a una funzione specifica del processo di analisi. Il progresso complessivo viene calcolato automaticamente come avanzamento ponderato delle singole fasi ed emesso in tempo reale al client tramite Server-Sent Events.

FASE	NOME	CONTENUTO
PHASE-01	INGESTION	Decompressione del pacchetto, enumerazione file, classificazione per estensione
PHASE-02	CLASSIFICATION	Identificazione tipologia documentale (visura, procedura, manuale, certificazione)
PHASE-03	OCR	Riconoscimento testo da scansioni e immagini tramite Azure Document Intelligence
PHASE-04	NORMALIZATION	Pulizia testo, deduplicazione, segmentazione in unità semantiche
PHASE-05	BATCHING	Raggruppamento documenti in lotti omogenei (max 10 doc / 100k char per batch)
PHASE-06	ANALYSIS	Generazione narrativa con LLM, una sintesi per documento (regola 1:1:1)
PHASE-07	AGGREGATION	Composizione del report finale, raggruppamento per macroaree tematiche
PHASE-08	DOCX BUILD	Generazione del documento Word strutturato con intestazione, indice e paragrafi

REGOLA 1:1:1 — TRACCIABILITÀ DOCUMENTALE

Ogni documento in input genera **una e una sola** sezione narrativa in output. Nessun documento viene "fuso" con altri, nessun paragrafo viene generato senza una sorgente documentale identificabile. Questa regola garantisce che ogni affermazione presente nel report sia tracciabile al documento di origine, eliminando il rischio di "allucinazione" tipico degli output generativi non vincolati. In contesti professionali questa proprietà è irrinunciabile: ogni evidenza riportata è verificabile sul documento sorgente.

Streaming Eventi (Server-Sent Events)

L'orchestrator emette eventi strutturati a ogni transizione significativa:

- `session.start` — inizio elaborazione, con metadati pacchetto
- `phase.start` — inizio di una fase
- `phase.tick` — avanzamento intra-fase (file N di M elaborato)
- `phase.end` — completamento fase, con metriche (durata, conteggi)
- `heartbeat` — segnale di liveness ogni 5 secondi (PID worker, memoria RSS)
- `done` — completamento con stats finali (durata totale, token usati, costo)
- `error` — errore terminale con tipo, messaggio e contesto

Performance Misurate in Produzione

Le seguenti metriche sono state misurate su elaborazioni reali. Includono l'intero ciclo di vita della richiesta, dal caricamento alla disponibilità del documento Word finale.

VOLUME PACCHETTO	DOCUMENTI	TEMPO END-TO-END	THROUGHPUT
~3 MB	9–11	35–45 secondi	~0.25 doc/sec
~25 MB	50–60	1m 50s – 2m 10s	~0.50 doc/sec
~90 MB	160–170	5m 20s	~0.51 doc/sec
~300 MB	300–310	7m 20s	~0.70 doc/sec
~660 MB	490–500	11m 30s	~0.72 doc/sec

RISULTATO

Il sistema scala in modo sub-lineare rispetto al volume del pacchetto: il throughput documenti/secondo migliora con il crescere della dimensione, grazie al batching parallelo. Un pacchetto di mezzo gigabyte di documenti viene completamente analizzato e sintetizzato in circa 11 minuti, contro le decine di ore necessarie a una lettura manuale equivalente.

Motore OCR: Azure Document Intelligence

Scelta Tecnologica

Per il riconoscimento del testo da PDF scansionati e immagini il sistema utilizza **Azure Document Intelligence Read API**, un servizio Microsoft di OCR di livello enterprise basato su modelli proprietari di visione artificiale ottimizzati per documenti aziendali e amministrativi.

- **Accuratezza superiore su documenti italiani strutturati** — visure, atti notarili, certificazioni, moduli amministrativi con layout complessi
- **Region europea con conformità GDPR contrattualizzata** — endpoint Sweden Central, dati non utilizzati per training di modelli
- **Throughput elevato e parallelismo gestito** — il servizio supporta nativamente chiamate concorrenti
- **SLA enterprise** — uptime garantito 99.9%, con compensazioni contrattuali

Configurazione di Esecuzione

PARAMETRO	VALORE	SIGNIFICATO
OCR_ENGINE	azure_di	Selezione esplicita del motore OCR
AZURE_DI_PARALLEL	15	Numero massimo di chiamate OCR concorrenti
AZURE_DI_REGION	swedencentral	Region europea per residenza dati
API version	2024-11-30	Modelli OCR più recenti, supporto multilingua

Tipologie Documentali Supportate

- **PDF nativi** (testo selezionabile) — estrazione diretta, senza OCR
- **PDF scansionati** (immagini) — OCR completo tramite Azure DI
- **PDF misti** (alcune pagine native, altre scansionate) — dispatch automatico
- **Immagini singole** (JPG, PNG, TIFF, HEIC) — OCR diretto
- **Documenti Office** (DOCX, XLSX) — estrazione testo nativa
- **File compressi annidati** (ZIP ricorsivi) — decompressione iterativa

Strategia di Fallback

Nel caso in cui una chiamata OCR fallisca per timeout, rate limit o errore transitorio, il sistema applica una politica di retry con backoff esponenziale (4 tentativi). Se anche il quarto tentativo fallisce, il documento

viene marcato come "non processabile" nel report finale, con annotazione esplicita. **Il sistema non inventa contenuti per documenti illeggibili.**

§
05

Motore di Sintesi: Azure OpenAI GPT-4.1-mini

Modello e Provider

La generazione della relazione narrativa è affidata a **GPT-4.1-mini erogato tramite Azure OpenAI**, in region Sweden Central. Questa scelta combina la qualità del modello con i requisiti contrattuali Azure: nessun utilizzo dei prompt e degli output per training di modelli pubblici, residenza dei dati garantita in EU, log di accesso disponibili per audit.

PARAMETRO	VALORE
Provider	Azure OpenAI Service
Modello	GPT-4.1-mini
Region	Sweden Central (EU)
API endpoint type	v1 (chat completions)
Output mode	<code>narrative</code> — testo libero strutturato
Token cap per batch	100.000 caratteri input
Max files per batch	10 documenti
Concorrenza	4 worker paralleli

Architettura del Prompt Narrativo

Il prompt sottoposto al modello impone vincoli espliciti su forma, contenuto e tracciabilità:

- **Lunghezza controllata** — ogni paragrafo tra 200 e 800 parole
- **Sottotitolo identificativo obbligatorio** — intestazione numerata + riferimento al documento sorgente
- **Varietà lessicale** — verbo iniziale ruotato deterministicamente (Esaminato, Acquisito, Verificato, Visionato, Consultato, Analizzato, Rilevato, Preso atto di)
- **Privacy by Design nel prompt** — il modello è istruito a non riportare dati personali identificativi non necessari
- **Tono oggettivo** — il modello non esprime giudizi, non formula raccomandazioni, non interpreta. Espone solo evidenze

■ Garanzia 1:1:1 Documento ↔ Paragrafo ↔ Output

Una caratteristica distintiva di DocSense rispetto a soluzioni generaliste di "AI summary" è la garanzia formale che **ogni documento in input genera esattamente un paragrafo in output**. Non esistono fusioni silenti, non esistono documenti dimenticati, non esistono paragrafi senza sorgente. Questa garanzia è enforced da un controllo post-generazione che:

1. Conta i documenti effettivamente forniti al batch (N)
2. Conta i paragrafi prodotti dal modello (P)
3. Se $N \neq P$, il batch viene rifiutato e re-inviato al modello con un prompt di correzione esplicito
4. Solo quando $N = P$ per tutti i batch, il report viene composto

ANTI-ALLUCINAZIONE BY CONSTRUCTION

Il modello non può "inventare" un documento che non esiste, e non può ignorare un documento che è stato fornito. Se un documento è illeggibile, il paragrafo corrispondente lo dichiara esplicitamente: "documento non processato — testo non riconoscibile". La trasparenza è una proprietà strutturale del sistema, non un valore opzionale. Ogni evidenza riportata è verificabile e difendibile rispetto al documento sorgente.

■ Gestione Rate Limit e Resilienza

Quando il provider risponde con un errore `429 Too Many Requests`, il sistema attiva una strategia di retry con backoff esponenziale (2s, 4s, 8s, 16s). Il jitter casuale aggiunto a ogni intervallo evita la "thundering herd". Dopo 4 retry falliti è prevista l'attivazione opzionale di un fallback secondario.

■ Token Metering e Trasparenza Operativa

Ogni elaborazione conserva il conteggio esatto dei token di input e output consumati. I dati permettono reportistica precisa per cliente / periodo, identificazione di anomalie (pratiche con consumo $>3\sigma$ rispetto alla media) e pianificazione capacità.

Sicurezza: Architettura a Difesa Stratificata

■ Principio Fondante: Defense in Depth

La sicurezza di DocSense non è affidata a un singolo punto di controllo. È implementata come una sequenza di livelli indipendenti: anche se uno di essi fosse compromesso, gli altri continuerebbero a proteggere i dati. Ogni livello applica controlli distinti, ed è documentato separatamente per facilitare le valutazioni di compliance.

L1 HOSTING FISICO IN TERRITORIO UE

Infrastruttura ospitata presso **Hetzner Online GmbH**, datacenter Falkenstein (Germania). Il provider è certificato ISO 27001, garantisce sovranità europea dei dati e dispone di clausole DPA standard. Il sistema non gira su provider con sede extra-UE.

L2 CIFRATURA IN TRANSITO (TLS 1.2+)

Tutte le comunicazioni esterne sono cifrate con TLS. Certificati X.509 emessi da Let's Encrypt con auto-renew ogni 90 giorni. Cipher suite limitate alle forward-secret (ECDHE) raccomandate da Mozilla SSL Configuration Generator. Redirect HTTP → HTTPS forzato.

L3 NETWORK HARDENING (NGINX)

Il reverse proxy applica controlli di sicurezza prima ancora che la richiesta raggiunga il backend: rate limiting (100 r/s per IP, burst 200), body size cap (1 GB), header di sicurezza completi, filtro contro path traversal e injection di header.

Security Headers HTTP

HEADER	VALORE	PROTEZIONE
Strict-Transport-Security	max-age=63072000; includeSubDomains	HTTPS forzato per 2 anni
X-Frame-Options	SAMEORIGIN	Previene clickjacking
X-Content-Type-Options	nosniff	Previene MIME type sniffing
Referrer-Policy	strict-origin-when-cross-origin	Limita leak di URL cross-origin
Permissions-Policy	camera=(), microphone=(), geolocation=()	Disabilita API hardware non necessarie

L4 AUTENTICAZIONE: JWT + BCRYPT

Accesso tramite credenziali username/password. Password hashate con **bcrypt** (cost factor 10, salt univoco). Sessioni gestite con **JWT** firmati HS256 con chiave segreta unica per deploy. Token con scadenza 8 ore, trasmessi solo via header `Authorization: Bearer`, mai in cookie persistenti.

L5 AUTORIZZAZIONE: ROLE-BASED ACCESS CONTROL

Ogni utente ha un ruolo (admin / user). Gli utenti standard vedono esclusivamente le proprie pratiche elaborate. L'isolamento è enforced a livello di query SQL: ogni accesso al database filtra automaticamente per username autenticato. Anche con un token valido, un utente non può accedere ai dati di un altro utente.

L6 PROCESSING IN REGION UE

I documenti caricati sono trasmessi esclusivamente agli endpoint Azure europei (Sweden Central). Microsoft garantisce contrattualmente che i contenuti trasmessi ad Azure OpenAI **non vengono utilizzati per training di modelli pubblici**. Le clausole sono nel Microsoft Products and Services Data Protection Addendum.

L7 STORAGE EFFIMERO DEI DOCUMENTI

I pacchetti documentali caricati non sono mai persistiti permanentemente. Vivono in una directory temporanea durante l'elaborazione, e vengono rimossi automaticamente al termine. Cleanup pianificato cron giornaliero alle 03:30 UTC. Filesystem cifrato a riposo con LUKS.

L8 AUDIT TRAIL COMPLETO

Ogni azione significativa è registrata: login, logout, upload pacchetto, completamento elaborazione, download report, accessi falliti. Ogni record include timestamp UTC, utente, tipo evento, IP di origine. L'audit log è esportabile per audit di conformità.

Modello di Minaccia Considerato

MINACCIA	CONTROMISURA
Intercettazione del traffico	TLS 1.2+ con cipher suite forward-secret
Brute force su login	bcrypt cost 10 + rate limit nginx
Furto del token JWT	Scadenza 8h + nessuna persistenza in cookie
Accesso cross-utente non autorizzato	Filtraggio enforced a livello SQL
SQL injection	Query parametrizzate (prepared statements) ovunque
XSS / clickjacking	Security headers HTTP + escaping in output
Path traversal / file inclusion	Validazione path lato server + chroot temp dir
Denial of Service	Rate limit + body size cap + timeout backend
Data leak ai provider AI	Solo provider EU + DPA contrattualizzato
Compromissione del server fisico	Filesystem cifrato LUKS, backup periodici

Gestione delle Credenziali e dei Segreti

- Le chiavi vivono in un file `.env` con permessi `0600`, accessibile solo all'utente di sistema che esegue il servizio
- Nessun segreto è committato nel repository sorgente
- Le chiavi non sono mai loggate, mai esposte in messaggi di errore, mai trasmesse al client
- Rotazione periodica pianificata delle API key dei provider esterni

§
07

GDPR Compliance: Mappatura Articolo per Articolo

Inquadramento del Trattamento

DocSense opera come **responsabile del trattamento** (Art. 28 GDPR) per conto dei propri clienti, che agiscono come **titolari del trattamento**. Il cliente conserva la piena titolarità dei dati personali contenuti nei documenti caricati. Axialoop di Di Lonardo Alessandro tratta tali dati esclusivamente per la finalità specifica dell'elaborazione tecnica richiesta, secondo istruzioni documentate, e per la durata strettamente necessaria al servizio.

Mappatura Articolo per Articolo

ARTICOLO	REQUISITO	IMPLEMENTAZIONE DOCSENSE
Art. 5(1)(a)	Liceità, correttezza, trasparenza	Base giuridica nel contratto cliente-titolare; DPA scritto
Art. 5(1)(b)	Limitazione delle finalità	Trattamento limitato all'elaborazione; nessun training di modelli
Art. 5(1)(c)	Minimizzazione dei dati	Solo i documenti necessari vengono trasmessi
Art. 5(1)(e)	Limitazione conservazione	Documenti caricati eliminati entro 24 h via cron
Art. 5(1)(f)	Integrità e riservatezza	TLS in transito + LUKS a riposo + JWT + RBAC
Art. 25	Privacy by Design e by Default	Hosting EU, processing EU, cancellazione automatica
Art. 28	Contratto con il responsabile	Template DPA standardizzato fornito al cliente
Art. 30	Registro attività di trattamento	Audit log SQLite + log JSONL per sessione
Art. 32	Sicurezza del trattamento	Architettura a 8 livelli (vedi § 06)
Art. 33	Notifica violazioni	Procedura formalizzata: notifica al titolare entro 24 h

ARTICOLO	REQUISITO	IMPLEMENTAZIONE DOCSENSE
Art. 35	Valutazione d'impatto (DPIA)	Modello DPIA disponibile a supporto del titolare
Art. 44-49	Trasferimenti verso paesi terzi	Nessun trasferimento extra-UE: hosting DE, OCR/LLM Sweden Central

■ Diritti degli Interessati

DIRITTO	SUPPORTO TECNICO FORNITO
Art. 15 — Accesso	Export su richiesta dei log relativi a una pratica specifica
Art. 16 — Rettifica	Sostituzione documenti su nuovo upload
Art. 17 — Cancellazione	Procedura di hard-delete su richiesta del titolare entro 72 h
Art. 18 — Limitazione	Sospensione elaborazioni su pratica specifica via flag
Art. 20 — Portabilità	Output in formato standard (DOCX, JSONL) trasferibili

■ Modello di Responsabilità

RUOLO	SOGGETTO	OBBLIGHI PRINCIPALI
Interessato	Persona fisica i cui dati sono nei documenti	Nessun obbligo; titolare di diritti
Titolare	Cliente che carica i documenti	Informativa, base giuridica, DPA, gestione richieste
Responsabile	Axialoop di Di Lonardo Alessandro	Misure tecniche, audit trail, notifica violazioni
Sub-responsabili	Microsoft Azure, Hetzner	DPA standard EU, no trasferimenti extra-UE

TRASPARENZA CONTRATTUALE

L'attivazione di una nuova installazione DocSense include sempre la firma di un Data Processing Agreement (DPA) basato sul template fornito da Axialoop. Il DPA elenca esplicitamente i sub-responsabili (Microsoft, Hetzner), i flussi di dati, le misure di sicurezza adottate, i tempi di conservazione e la procedura di notifica violazioni.

■ Posizione su Training di Modelli AI

I contenuti dei documenti caricati e i prompt sottoposti ai modelli LLM **non vengono utilizzati per addestrare modelli di intelligenza artificiale**, né da Axialoop né da Microsoft. Questo è garantito contrattualmente da Microsoft per Azure OpenAI Service tramite il Microsoft Products and Services Data Protection Addendum e da Axialoop nel proprio DPA con il titolare.

§ 08

Modello di Deploy: Tenant Dedicato

Architettura Single-Tenant per Cliente

DocSense viene installato in modalità **tenant dedicato**: ogni cliente riceve un'istanza isolata del sistema, con il proprio dominio, le proprie credenziali, il proprio database, i propri log e le proprie chiavi API. Non esiste una piattaforma SaaS condivisa con account multipli — ogni deploy è un ambiente a sé stante.

- **Isolamento totale** dei dati tra clienti diversi — zero contaminazione cross-tenant
- **Personalizzazione su misura** — prompt, macroaree, template configurabili
- **Branding white-label** — interfaccia e documenti con il brand del cliente

Componenti di un Deploy Standard

COMPONENTE	DETTAGLIO
Sottodominio dedicato	<code>cliente.docsense.app</code> o dominio personalizzato
Server cloud	VPS Hetzner con risorse dimensionate al volume previsto
Certificato TLS	Let's Encrypt con auto-renew
Database	SQLite locale al server, backup giornaliero automatico
Azure OpenAI	Deployment dedicato o quota condivisa, configurato in EU
Azure Document Intelligence	Risorsa dedicata o condivisa, sempre in EU
Utenti applicativi	Configurati dal cliente, ruoli admin/user
Branding	Logo, intestazioni documenti, colore tema
Profilo verticale	Configurazione framework normativo (vedi § 09)

CONSEGUENZA DIRETTA SUL GDPR

Il modello single-tenant elimina alla radice una categoria intera di rischi GDPR: quelli derivanti dalla coabitazione di dati di titolari diversi sulla stessa infrastruttura logica. Ogni cliente ha la garanzia tecnica che i propri dati non condividono mai memoria, processo, database o filesystem con dati di altri clienti.

Framework Pre-Configurati e Verticali Applicativi

Il Problema Generale: Volume Documentale & Sintesi Tracciabile

In molti settori professionali — gestione documentale aziendale, compliance normativa, consulenza tecnica, due diligence, verifica di conformità, screening di fornitori — l'analisi di pacchetti documentali estesi rappresenta una fase critica che condiziona tempi e qualità dell'intero processo. La lettura sistematica di 200–500 documenti eterogenei richiede tipicamente giornate di lavoro, con un rischio non trascurabile di campionamento parziale, di omissioni e di disomogeneità nello stile della relazione finale.

DocSense risponde a questo problema strutturale leggendo *tutti* i documenti del pacchetto in modo deterministico e sistematico, e producendo una relazione narrativa strutturata in formato Word, pronta per essere utilizzata come base di lavoro. L'output mantiene la tracciabilità documento-paragrafo (regola 1:1:1) e segue uno schema riproducibile e coerente.

10 Framework Normativi Pre-Configurati

Il sistema è già configurato per operare sui seguenti 10 framework normativi e di settore, con prompt, macroaree e logiche di estrazione tarate sullo specifico standard di riferimento:

ISO 9001 — Qualità

ISO 14001 — Ambiente

ISO 45001 — Salute & Sicurezza

ISO 27001 — Sicurezza Informazioni

ISO 13485 — Dispositivi Medici

ISO 22000 — Sicurezza Alimentare

ISO 50001 — Gestione Energia

ISO 37001 — Anticorruzione

SA 8000 — Responsabilità Sociale

ESG / CSRD-ESRS — Sostenibilità

Per ciascuno di questi framework, DocSense include: un **prompt specifico** tarato sullo standard, una **griglia di macroaree** coerente con la struttura della norma, un **template DOCX** di output, e un **set di pattern di estrazione metadati** (riconoscimento certificato, ente di certificazione, scope, validità).

ESTENDIBILITÀ GARANTITA

L'architettura non è cablata sui 10 framework attuali: l'aggiunta di uno nuovo richiede esclusivamente la creazione di un profilo di configurazione (prompt + macroaree + template + pattern). Nessuna modifica al codice del motore. Un nuovo framework può essere reso operativo in pochi giorni di lavoro di configurazione e validazione.

Versatilità ad Altri Domini Applicativi

Il motore di DocSense è strutturalmente agnostico al dominio applicativo. Cambiando i tre artefatti di configurazione (prompt narrativo, macroaree tematiche, template DOCX), il sistema si applica a qualunque attività professionale che richieda l'analisi sistematica di pacchetti documentali e la produzione di report strutturati e tracciabili.

DOMINIO APPLICATIVO	TIPOLOGIA DOCUMENTI	OUTPUT TIPICO
Verifica documentale di conformità	Manuali, procedure, registrazioni, certificazioni	Relazione di evidenze per macroaree del framework
Gap analysis preliminare	Documentazione attuale dell'organizzazione	Mappatura presidi vs requisiti, identificazione gap
Compliance ambientale industriale	Autorizzazioni AIA/AUA, dichiarazioni rifiuti, VIA	Relazione di adeguatezza per autorizzazioni o rinnovi
Sicurezza sul lavoro (D.Lgs. 81/08)	DVR, DUVRI, formazione, sorveglianza, DPI, verbali	Mappatura evidenze per macroaree di sicurezza
Due diligence M&A	Bilanci, contratti, atti societari, contenziosi, IP	Memorandum di sintesi per area di rischio
Compliance privacy / sicurezza informazioni	Policy, procedure, registri trattamenti, valutazioni	Inventario evidenze per controlli normativi
Compliance 231 (responsabilità enti)	MOG, procedure di controllo, formazione, OdV	Mappatura presidi per categorie di reato presupposto
Qualifica e screening fornitori	Certificazioni, schede tecniche, dichiarazioni	Scheda di qualifica standardizzata e comparabile
Screening documentale legale	Contratti, scritture private, contenziosi	Sintesi tematica con evidenze testuali oggettive
Bandi e appalti pubblici	Documentazione tecnica e amministrativa di gara	Relazione di completezza e conformità al disciplinare
Reporting di sostenibilità	Bilanci ESG, dichiarazioni non finanziarie	Sintesi strutturata per area di rendicontazione

Cosa Si Configura per un Nuovo Verticale

- Prompt narrativo** — riscritto per riflettere linguaggio, obiettivi e vincoli del dominio
- Macroaree tematiche** — categorie usate per raggruppare i paragrafi nel report finale
- Template DOCX di output** — intestazione, logo, struttura indice, formattazione

4. **Regole di estrazione metadati** — pattern per riconoscere automaticamente nome cliente, P.IVA, codici progetto

§ 10

Continuità Operativa e Backup

Backup Automatici Giornalieri

Il database SQLite del sistema viene salvato automaticamente ogni notte alle 03:15 UTC tramite un job cron pianificato. I backup vengono:

- Compresi con gzip (riduzione tipica 5–10×)
- Nominati con la data del backup (es. `daily_20260508.db.gz`)
- Conservati per 30 giorni in rotazione
- Verificati con checksum SHA-256 al momento della scrittura

In aggiunta ai backup giornalieri, viene conservato uno snapshot mensile permanente per i successivi 12 mesi.

Procedura di Disaster Recovery

1. **Provisioning nuovo server** — VPS Hetzner identico, configurato via Ansible (~15 minuti)
2. **Ripristino del DB** — backup gzip decompresso, controllo integrità con `PRAGMA integrity_check`
3. **Riconfigurazione DNS** — record A/AAAA puntato al nuovo IP (TTL 300 s)
4. **Re-issue certificato TLS** — Let's Encrypt rilascia un nuovo cert in pochi minuti
5. **Smoke test** — login, lista pratiche, upload pacchetto demo, generazione report

RPO E RTO INDICATIVI

Recovery Point Objective (RPO): al massimo 24 ore.

Recovery Time Objective (RTO): 2–4 ore, in funzione della tempestività.

Per scenari business-critical sono disponibili upgrade architetturali (backup off-site continuo, replica master-slave) discussi nella sezione Roadmap.

Cleanup Automatico dei Dati Temporanei

Un secondo job cron alle 03:30 UTC rimuove automaticamente i file temporanei prodotti dalle elaborazioni del giorno: pacchetti decompressi, file OCR intermedi, output DOCX intermedi, cache di sessione >24h. Il log di cleanup è conservato per evidenza di compliance.

Monitoraggio e Osservabilità

■ Logging Strutturato

- **Log applicativo** — emesso da FastAPI tramite stdout, raccolto da `systemd-journald`. Interrogabile con `journalctl`.
- **Log di sessione (JSONL)** — un file per elaborazione. Ogni riga è un evento JSON timestampato. Consente analisi forense puntuale di ogni singola pratica elaborata.

■ Health Check e Liveness

Il sistema espone un endpoint `/api/health` che restituisce in JSON lo stato dei componenti: connettività al DB, raggiungibilità Azure, occupazione disco, worker attivi. Integrabile con monitoring esterno (UptimeRobot, Better Stack) per allerta proattiva.

■ Heartbeat di Sessione

Durante ogni elaborazione, il worker emette un evento `heartbeat` ogni 5 secondi con metriche di processo (PID, RSS, profondità coda, task in volo). L'assenza di heartbeat per più di 30 secondi su una sessione attiva genera un evento di errore.

■ Token Metering e Reportistica Tecnica

Ogni chiamata ai provider AI è tracciata con il consumo esatto di token. I dati permettono: reportistica tecnica del consumo per cliente / periodo, allerta su anomalie, pianificazione capacità.

TRASPARENZA OPERATIVA

Il cliente ha sempre accesso al consumo tecnico effettivo della propria istanza. Ogni elaborazione è riconducibile a metriche oggettive: tempo, token, dimensione documenti, esito.

§ 12

Roadmap di Evoluzione

Questa sezione documenta le direzioni di sviluppo identificate per le versioni successive di DocSense. Ogni punto descrive una funzionalità non ancora implementata, il problema che risolverebbe e come si integrerebbe nell'architettura esistente.

■ 12.1 — Autenticazione Multi-Fattore (MFA)

Cosa sarebbe: aggiunta di un secondo fattore di autenticazione (TOTP via app come Authy o Google Authenticator, oppure WebAuthn / passkey) per tutti gli utenti.

Cosa risolverebbe: il furto di password non basterebbe più per accedere al sistema. Innalza significativamente il bar di sicurezza, anche in vista di certificazioni ISO 27001.

■ 12.2 — Backup Off-Site Cifrato

Cosa sarebbe: replica giornaliera dei backup verso un secondo provider cloud europeo indipendente (OVH, Scaleway, Backblaze EU), con cifratura client-side.

Cosa risolverebbe: elimina il single point of failure rappresentato dalla coincidenza tra server primario e archivio backup. Garantisce business continuity anche in caso di compromissione completa del provider primario.

■ 12.3 — Catalogo Multi-Verticale Espanso

Cosa sarebbe: ampliamento della libreria di profili pre-configurati oltre i 10 framework attuali (es. IATF 16949, AS 9100, TISAX, NIS2, AI Act).

Cosa risolverebbe: riduce drasticamente il time-to-value per nuovi clienti in settori specifici e abilita un onboarding rapido su norme di nicchia.

■ 12.4 — Modulo di Verifica Conformità Assistita

Cosa sarebbe: uno strato applicativo opzionale che, oltre a sintetizzare le evidenze, propone una *checklist preliminare* di copertura rispetto al framework selezionato, con citazione esplicita del documento e del passaggio testuale rilevante.

Cosa risolverebbe: accorcia la distanza tra "lettura documenti" e "redazione della relazione finale", mantenendo intatta la responsabilità professionale.

Le funzionalità descritte non sono parte del sistema attuale. Rappresentano direzioni di sviluppo identificate sulla base dell'architettura esistente.

§ 13

Glossario Tecnico

TERMINE	SIGNIFICATO PRATICO
OCR <i>Optical Character Recognition</i>	Tecnologia che converte immagini di testo in testo digitale modificabile
LLM <i>Large Language Model</i>	Modello di intelligenza artificiale per il linguaggio naturale
Pacchetto documentale	Insieme strutturato di documenti relativi a un cliente o un caso, fornito come archivio compresso
Framework normativo	Insieme strutturato di requisiti rispetto ai quali la documentazione viene analizzata
JWT <i>JSON Web Token</i>	Credenziale cifrata che identifica l'utente per ogni richiesta, valida per un periodo limitato
bcrypt	Algoritmo di hashing per password progettato per essere lento e resistente a brute force
TLS <i>Transport Layer Security</i>	Protocollo di cifratura che protegge le comunicazioni tra browser e server (la "S" di HTTPS)
DPA <i>Data Processing Agreement</i>	Contratto che disciplina il trattamento dei dati personali tra titolare e responsabile
RPO <i>Recovery Point Objective</i>	Massima quantità di dati che si può tollerare di perdere in caso di incidente
RTO <i>Recovery Time Objective</i>	Tempo massimo accettabile per ripristinare l'operatività dopo un incidente
SSE <i>Server-Sent Events</i>	Tecnologia che permette al server di inviare aggiornamenti in tempo reale al browser
JSONL <i>JSON Lines</i>	Formato in cui ogni riga è un oggetto JSON autonomo, ideale per log strutturati
Tenant	Istanza isolata del sistema dedicata a un singolo cliente
White-label	Modalità di distribuzione in cui il prodotto è presentato con il brand del cliente

TERMINE	SIGNIFICATO PRATICO
DPIA <i>Data Protection Impact Assessment</i>	Valutazione d'impatto sulla protezione dei dati, prevista dall'art. 35 GDPR
RBAC <i>Role-Based Access Control</i>	Sistema di permessi basato sul ruolo dell'utente (admin, user)